



UNIVERSIDAD PERUANA LOS ANDES

Facultad de Ingeniería

Escuela Profesional de Ingeniería de Sistemas

SEGURIDAD Y CUMPLIMIENTO EN SQL SERVER: CONTROL DE ACCESOS, CIFRADO, AUDITORÍA Y PROTECCIÓN DE DATOS



Alumno : Diego Michael Vilchez Estrada
Curso : Bases de Datos II
Docente : Raul Enrique Fernandez Bejarano
Fecha : Mayo de 2025



AUTENTICACIÓN WINDOWS vs. SQL SERVER EN ENTORNOS UNIVERSITARIOS



Elegir el método de autenticación adecuado mejora la seguridad, facilita la administración y reduce riesgos en la gestión de bases de datos.

1. AUTENTICACIÓN WINDOWS

VS.

2. AUTENTICACIÓN SQL SERVER



Acceso para Personal Académico/Interno

Utiliza cuentas de dominio institucional (Active Directory). Ideal para docentes, administradores y personal interno de la universidad.



Acceso para Consultores Externos

Usa cuentas propias de SQL Server. Recomendado para consultores, terceros o usuarios que no pertenecen al dominio institucional.



Ventajas de Kerberos

- ✓ Autenticación mutua entre cliente y servidor.
- ✓ No se envían contraseñas por la red.
- ✓ Utiliza tickets cifrados con tiempo de vida limitado.
- ✓ Mayor resistencia a ataques como "pass-the-hash".



Políticas de Contraseñas Complejas

- ✓ Longitud mínima de 12 caracteres.
- ✓ Debe incluir mayúsculas, minúsculas, números y símbolos.
- ✓ Expiración periódica.
- ✓ Evitar reutilización de contraseñas.



Single Sign-On (SSO)

El usuario inicia sesión una sola vez en su equipo institucional y puede acceder a los recursos de SQL Server sin volver a ingresar credenciales.



¿Cuándo usarla?

- Acceso de consultores o proveedores externos.
- Aplicaciones o servicios que requieren conexión programática.
- Escenarios donde no existe integración con Active Directory.



Ideal para:

- Red interna universitaria.
- Ambientes bajo dominio (Active Directory).
- Simplificar la administración de usuarios.



Consideraciones:

- Mayor responsabilidad en la gestión de usuarios.
- Riesgo más alto si las contraseñas son débiles.
- Requiere políticas estrictas de seguridad.



3. PRÁCTICAS SEGURAS PARA MITIGAR ATAQUES DE FUERZA BRUTA

1 Habilitar Bloqueo de Cuenta



Configurar la política de bloqueo de cuentas para bloquear temporalmente al usuario después de varios intentos fallidos.

Ejemplo: Bloquear después de 5 intentos fallidos por 15 minutos.

2 Limitar y Monitorear Conexiones



Monitorear intentos de inicio de sesión fallidos y limitar el número de conexiones por IP o por usuario en SQL Server.

Usar Extended Events, SQL Server Audit y Alertas del Agente.

3 Usar Autenticación Fuerte



Siempre que sea posible, preferir la Autenticación Windows. Si se usa SQL Server Authentication, aplicar contraseñas fuertes y MFA en aplicaciones web.

La MFA (Autenticación Multifactor) añade una capa extra de seguridad.



RECUERDA: La seguridad en SQL Server es un proceso continuo. Evaluar, auditar y fortalecer las configuraciones de autenticación protege la información académica y administrativa.





HARDENING Y CONFIGURACIÓN SEGURA DE SQL SERVER EN PRODUCCIÓN

Buenas prácticas para reducir la superficie de ataque, proteger los datos y garantizar la estabilidad del servidor.



1 CONFIGURACIÓN DE CUENTAS DE SERVICIO

Principio de privilegios mínimos



Usar cuentas de servicio gestionadas por Microsoft (MSA/gMSA)

Evita el uso de cuentas locales o credenciales con privilegios elevados.



Principio de privilegios mínimos

- Asignar solo los permisos necesarios para ejecutar SQL Server y SQL Server Agent.
- No agregar las cuentas a grupos locales como Administrators.
- Sin inicio de sesión interactivo.



Beneficios

- Mayor seguridad.
- Rotación automática de contraseñas.
- Menor impacto ante compromisos.



Cuentas recomendadas

Servicio SQL Server

Cuenta gMSA
(Ej. DOMINIO\sqlsvc\$)

SQL Server Agent

Cuenta gMSA
(Ej. DOMINIO\sqlagent\$)



Recomendación adicional

- Asegurar que la cuenta gMSA tenga permisos NTFS mínimos sobre las rutas de datos, logs y backups.
- Registrar la cuenta del servicio en Active Directory.

2 PROTOCOLOS DE RED SEGUROS

Reducir la superficie de ataque en la capa de transporte



Deshabilitar Named Pipes

No es necesario en la mayoría de entornos y puede ser explotado localmente.



Forzar cifrado SSL/TLS

Cifrar todas las conexiones para proteger credenciales y datos en tránsito.



Cambiar el puerto por defecto

Evitar el uso del puerto 1433 (bien conocido) para dificultar escaneos automatizados.



Named Pipes

Estado: Deshabilitado



TCP/IP

Estado: Habilitado



Cifrado

Forzar cifrado: SI (SSL/TLS)



Puerto

Cambiar puerto (ej. 51433)

Pasos clave

- ✓ Deshabilitar Named Pipes desde SQL Server Configuration Manager.
- ✓ Habilitar Force Encryption en SQL Server Configuration Manager.
- ✓ Usar un certificado válido (emitido por una CA interna o pública).
- ✓ Permitir el nuevo puerto en el Firewall del servidor y de red.

3 MONITOREO DE SERVICIOS CRÍTICOS

Usar vistas de sistema (DMVs) para detectar y prevenir problemas



El monitoreo continuo permite identificar cuellos de botella, bloqueos, alto consumo de recursos y sesiones maliciosas.

DMVs esenciales para monitoreo

sys.dm_exec_requests

Muestra las solicitudes en ejecución actualmente (CPU, waits, tiempo, etc.).

sys.dm_exec_sessions

Lista todas las sesiones conectadas al servidor.

sys.dm_db_index_physical_stats

Nivel de fragmentación de índices para mantenimiento.

sys.dm_os_wait_stats

Muestra las esperas acumuladas del servidor (recursos en espera).

sys.dm_os_process_memory

Información de uso de memoria por el motor de SQL Server.

sys.dm_tran_locks

Bloqueos actuales (útil para detectar contención y bloqueos maliciosos).



```
-- Solicitudes en ejecución
SELECT session_id, status, command,
       cpu_time, total_elapsed_time, wait_type,
       wait_time, blocking_session_id
FROM sys.dm_exec_requests
ORDER BY total_elapsed_time DESC;
```

Acciones recomendadas

- ✓ Revisar periódicamente sesiones, bloqueos y esperas.
- ✓ Crear alertas para umbrales críticos de CPU, memoria y disco.
- ✓ Implementar auditoría y registros extendidos (XEvent).
- ✓ Revisar y planificar mantenimiento preventivo.



ARQUITECTURA DE ROLES EN LA BASE DE DATOS GRADOS Y TÍTULOS

Control de accesos basado en roles personalizados por esquema del sistema para garantizar seguridad, trazabilidad y segregación de funciones.



1. ROLES POR ESQUEMAS DEL SISTEMA (SEGURIDAD POR MÓDULOS)

Cada esquema agrupa objetos lógicos (tablas, vistas, procedimientos) y tiene roles específicos con permisos definidos.



2. ROLES ESPECÍFICOS PARA EVALUADORES DE TESIS

Los evaluadores (jurados) requieren acceso limitado y controlado para consultar información y registrar sus observaciones.



rol_evaluador_tesis

Permite a los jurados consultar el trabajo de investigación asignado y registrar sus observaciones y calificación.

PERMISOS DE CONSULTA

- SELECT en tablas de:
 - ✓ Trabajos de Investigación
 - ✓ Estudiantes
 - ✓ Planes de Estudio
 - ✓ Documentos del Trabajo (solo lectura)



PERMISOS DE REGISTRO

- INSERT en Observaciones
- INSERT/UPDATE en Evaluaciones (solo sus propias evaluaciones)
- Sin permisos de modificación o eliminación de documentos



El acceso del evaluador está restringido únicamente a los trabajos que le han sido asignados.

3. PIRÁMIDE DE ROLES JERÁRQUICOS (SEGREGACIÓN DE FUNCIONES)

Los roles se organizan jerárquicamente para controlar el nivel de acceso y responsabilidad.



PRINCIPIOS APLICADOS



Mínimo Privilegio

Cada rol tiene solo los permisos necesarios para su función.



Segregación de Funciones

Las tareas críticas se distribuyen entre roles diferentes.



Trazabilidad

Todas las acciones se registran para auditoría y control.



Una arquitectura de roles bien diseñada protege la información, reduce riesgos y garantiza la integridad del proceso de grados y títulos.



EL CICLO DEL PERMISO EN SQL: GRANT, DENY Y REVOKE

Ejemplo práctico aplicado a la Oficina de Grados y Títulos

El control de permisos en SQL Server garantiza que cada usuario o rol solo acceda a lo que necesita para su función, protegiendo la integridad y confidencialidad de la información académica.

Objetivo
Aplicar el principio de mínimo privilegio para asegurar datos críticos como resoluciones, diplomas y expedientes.

1 GRANT

Permitir lectura a Operadores en datos de estudiantes.



Datos permitidos:
Estudiantes
(Vista o Consulta de Información)



¿Qué hace?

Concede permisos específicos a un usuario o rol para realizar acciones sobre objetos de la base de datos.

EJEMPLO PRÁCTICO

```
-- 1. Crear rol para operadores
CREATE ROLE rol_operador;

-- 2. Agregar usuarios al rol
EXEC sp_addrolemember 'rol_operador', 'usuario_maria';
EXEC sp_addrolemember 'rol_operador', 'usuario_juan';

-- 3. Conceder permiso de lectura
GRANT SELECT ON dbo.Estudiantes
TO rol_operador;

-- (Opcional) Limitar a vista específica
GRANT SELECT ON dbo.vw_Estudiantes_Basicos
TO rol_operador;
```

RESULTADO

Los operadores pueden consultar la información de estudiantes, pero no modificarla.



Acceso de lectura permitido

Verificación rápida

```
SELECT * FROM fn_my_permissions
(NULL, 'DATABASE');
```

2 DENY

Restringir de forma estricta la modificación de resoluciones y diplomas a personal no autorizado.



Objetos críticos:
Resoluciones
Diplomas



¿Qué hace?

Niega explícitamente un permiso. Tiene precedencia sobre cualquier GRANT heredado por roles.

EJEMPLO PRÁCTICO

```
-- 1. Denegar modificación a operadores
DENY INSERT, UPDATE, DELETE ON dbo.Resoluciones
TO rol_operador;
DENY INSERT, UPDATE, DELETE ON dbo.Diplomas
TO rol_operador;

-- 2. (Opcional) Denegar a usuarios específicos
DENY INSERT, UPDATE, DELETE ON dbo.Resoluciones
TO usuario_maria;

-- Nota: DENY prevalece incluso si el rol padre
tiene permisos de escritura.
```

RESULTADO

Los operadores NO pueden modificar resoluciones ni diplomas.



Modificación bloqueada

Verificación rápida

```
SELECT * FROM fn_my_permissions
(NULL, 'DATABASE');
```

-- El permiso debe aparecer como DENY

3 REVOKE

Revocar de forma limpia accesos temporales otorgados a auditores externos tras finalizar su periodo.



Acceso temporal por auditoría



¿Qué hace?

Elimina permisos previamente otorgados (GRANT o DENY). Restaura el estado anterior sin dejar accesos innecesarios.

EJEMPLO PRÁCTICO

```
-- 1. Durante la auditoría, se otorga acceso
GRANT SELECT ON dbo.Reportes_Grados_Titulos
TO auditor_externo;

-- 2. Al finalizar el periodo, revocar permisos
REVOKE SELECT ON dbo.Reportes_Grados_Titulos
FROM auditor_externo;

-- 3. (Opcional) Quitar del rol temporal
EXEC sp_droprolemember 'rol_auditoria', 'auditor_externo';
```

RESULTADO

El auditor externo pierde el acceso a la información una vez finalizado su trabajo.



Acceso revocado

Verificación rápida

```
SELECT * FROM fn_my_permissions
(NULL, 'DATABASE');
```

-- No debe mostrar el permiso

RESUMEN DEL CICLO DEL PERMISO



BUENAS PRÁCTICAS

- ✓ Aplicar el principio de mínimo privilegio.
- ✓ Documentar cada cambio de permiso.
- ✓ Usar roles en lugar de permisos directos.
- ✓ Revisar y auditar permisos periódicamente.
- ✓ Revocar accesos que ya no sean necesarios.



Un ciclo de permisos bien gestionado protege la información académica, asegura el cumplimiento y fortalece la confianza institucional.



Oficina de Grados y Títulos

PROTECCIÓN FÍSICA CON TRANSPARENT DATA ENCRYPTION (TDE)

Cifrado en reposo para proteger los archivos de datos y backups de la base de datos GradosTítulos ante accesos no autorizados.



¿CÓMO FUNCIONA TDE? FLUJO DE CIFRADO EN REPOSO



JERARQUÍA DE CLAVES EN TDE



Si una de las claves se ve comprometida, las capas superiores siguen protegiendo las claves y los datos. Esta jerarquía asegura la confidencialidad de los datos en reposo.

¿QUÉ SE CIFRA CON TDE?



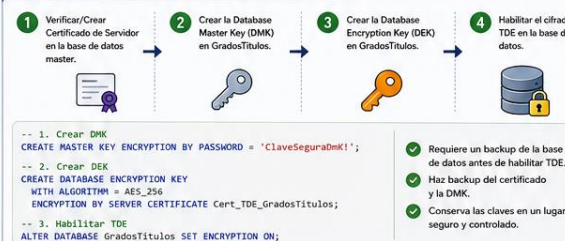
IMPACTO EN EL RENDIMIENTO



Buenas prácticas:

- Asegurar hardware compatible con cifrado por hardware.
- Monitorear I/O y CPU después de habilitar TDE.
- Mantener el sistema operativo y controladores actualizados.

PASOS PARA HABILITAR TDE EN GradosTítulos



EN RESUMEN

TDE protege los datos en reposo cifrando los archivos .mdf, .ldf y los backups de la base de datos GradosTítulos sin cambios en las aplicaciones. La jerarquía de claves garantiza que, incluso si se accede a los archivos físicamente, los datos permanezcan ilegibles.

RECUERDA
Protección en reposo es una capa esencial de seguridad. Combinada con control de accesos, auditoría y copias de seguridad para una estrategia completa.

ALWAYS ENCRYPTED: PROTEGIENDO LOS DATOS SENSIBLES DEL TESISISTA

Cifrado en el lado del cliente para proteger la confidencialidad de los datos personales, incluso de administradores de la base de datos.

¿QUÉ ES ALWAYS ENCRYPTED?



Always Encrypted permite cifrar datos sensibles en el lado del cliente (aplicación) antes de que se envíen a SQL Server. SQL Server almacena y procesa los datos cifrados sin tener acceso a las claves, por lo que nunca puede ver la información en texto plano.

DATOS SENSIBLES DEL TESISISTA

Ejemplos de información personal que debe protegerse:



DNI



Correo Electrónico



Teléfono

TIPOS DE CIFRADO EN ALWAYS ENCRYPTED

CIFRADO DETERMINISTA



- El mismo valor siempre genera el mismo texto cifrado.
- Permite búsquedas y comparaciones de igualdad (=), JOIN, GROUP BY, índices.
- Útil para campos como DNI.

Ejemplo: DNI



Valor en texto plano	Valor cifrado (determinista)
71543210	0x1B2C3D4E5F60789
71543210	0x1B2C3D4E5F60789
72455678	0x9F8E7D6C5B4A3210

✓ Permite buscar: DNI = 71543210

VS

CIFRADO ALEATORIO



- El mismo valor genera textos cifrados diferentes cada vez.
- No permite búsquedas por igualdad.
- Máxima protección para datos altamente sensibles.
- Útil para campos como Correo y Teléfono.

Ejemplo: Correo Electrónico



Valor en texto plano	Valor cifrado (aleatorio)
maria.torres@uni.edu.pe	0x1B7E9C0A2D3F44B1
maria.torres@uni.edu.pe	0x8C2D4E6F9A0B7C11
maria.torres@uni.edu.pe	0x77A1F2C3B4E5D688

✗ No permite buscar por igualdad

CÓMO VIAJAN LOS DATOS CIFRADOS (FLUJO DE EXTREMO A EXTREMO)



¿POR QUÉ EL DBA NO PUEDE VER LA INFORMACIÓN EN TEXTO PLANO?



Las claves privadas nunca salen del cliente/aplicación. El DBA no puede descifrar los datos aunque tenga acceso total al servidor.

JERARQUÍA DE CLAVES (RESUMEN)



BENEFICIOS CLAVE

- ✓ Protege datos sensibles incluso de administradores de la BD.
- ✓ Reduce el riesgo de fuga de información.
- ✓ Cumple con normativas de privacidad (Ley N.º 29733, GDPR, ISO 27001).
- ✓ Protección transparente para las aplicaciones (sin cambiar la lógica de negocio).

RECOMENDACIÓN

Usar Always Encrypted para DNI (determinista) y Correo/Teléfono (aleatorio) en la base de datos Grados/Títulos asegura la confidencialidad de los datos personales del tesisista.

SISTEMA INTEGRAL DE AUDITORÍA EN GRADOS Y TÍTULOS

Monitoreo, registro y análisis continuo para garantizar la trazabilidad, transparencia e integridad de los procesos académicos.

CENTRO DE MONITOREO Y AUDITORÍA

ESTADO DEL SISTEMA

AUDITORÍA ACTIVA
Todos los eventos siendo registrados

Eventos hoy
12,458

Alertas críticas
3

EVENTOS POR CATEGORÍA



EVENTOS POR HORA (HOY)



EVENTOS CRÍTICOS RECIENTES

- Eliminación de usuario 10:21
- Cambio de rol crítico 09:47
- UPDATE en Trámite Resolución 09:12
- Intento de login fallido 09:03
- GRANT de permisos 08:55

AUDITORÍA ALMACENADA EN

Base de datos de auditoría (immutable)
Retención: 365 días

EVENTOS AUDITADOS

1 INICIOS DE SESIÓN (LOGINS)

Registra cada intento y éxito de inicio de sesión al sistema.



SE REGISTRA:

- Usuario
- Fecha y hora
- Dirección IP
- Resultado (Éxito/Fallo)
- Aplicación origen

2 CAMBIOS DE PERMISOS

Audita la modificación de roles, permisos y asignaciones.



SE REGISTRA:

- Usuario que realiza el cambio
- Tipo de cambio (GRANT, REVOKE)
- Permiso/Objeto afectado
- Antes y después del cambio
- Fecha y hora

3 CREACIÓN / ELIMINACIÓN DE USUARIOS Y OBJETOS

Controla la creación o eliminación de usuarios, roles, tablas, vistas, procedimientos y otros objetos.



SE REGISTRA:

- Tipo de objeto (Usuario, Rol, Tabla, etc.)
- Acción (CREATE / DROP)
- Nombre del objeto
- Usuario ejecutor
- Fecha y hora

4 MODIFICACIONES CRÍTICAS EN ESQUEMA TRAMITE

Registra operaciones INSERT, UPDATE y DELETE sobre datos críticos del esquema Trámite.



SE REGISTRA:

- Tipo de operación (INSERT, UPDATE, DELETE)
- Tabla y registro afectado
- Valores antes y después (cuando aplique)
- Usuario ejecutor
- Fecha y hora
- Aplicación origen

FLUJO DE AUDITORÍA



CARACTERÍSTICAS CLAVE

- ✓ Inmutable: Protección contra alteraciones.
- ✓ Retención: Conservación según políticas (ej. 1 año).
- ✓ Confidencial: Acceso restringido a personal autorizado.
- ✓ Trazable: Cada evento tiene un rastro único.

¿POR QUÉ LA AUDITORÍA GARANTIZA TRAZABILIDAD E INTEGRIDAD ACADÉMICA?

- ✓ DETECCIÓN DE FRAUDES: Permite identificar acciones inusuales o no autorizadas sobre datos académicos sensibles (notas, trámites, resoluciones, diplomas).
- ✓ TRAZABILIDAD COMPLETA: Cada acción queda asociada a un usuario, hora y origen, permitiendo reconstruir el historial completo de cambios.
- ✓ INTEGRIDAD DE LOS DATOS: Cualquier modificación indebida puede ser detectada y revertida, asegurando la veracidad de la información académica.
- ✓ CUMPLIMIENTO NORMATIVO: Cumple con regulaciones de protección de datos, transparencia y control interno (Ley N.º 29733, ISO/IEC 27001, buenas prácticas IT).
- ✓ RESPONSABILIDAD Y RENDICIÓN DE CUENTAS: Promueve una cultura de responsabilidad al saber que todas las acciones quedan registradas y auditadas.

COMANDOS Y HERRAMIENTAS UTILIZADAS

- SQL Server Audit
- Extended Events (para auditoría avanzada)
- Almacenamiento en archivos .sqldiag o en tabla
- Visor de Auditoría de SQL Server / SSMS
- Reportes y alertas automatizadas

EJEMPLO DE EVENTO REGISTRADO

```
{
  "event_time": "2025-05-21T10:21:34Z",
  "action_id": "UPDATE",
  "schema_name": "Trámite",
  "object_name": "Resolución",
  "user_name": "operador_grados",
  "ip_address": "192.168.10.25",
  "success": true,
  "application_name": "SISTEMA_GRADOS_TITULOS"
}
```

EN RESUMEN



La auditoría continua es la base para un sistema de Grados y Títulos confiable, transparente y resistente a fraudes, asegurando que cada decisión académica esté respaldada por datos íntegros y verificables.

AUDITAR HOY, PROTEGER SIEMPRE